MIND THE GAP:
SECURITY ON PAPER, REALITY ON THE WIRE

MANDIE GROSSKOPF

AGENDA

1. Introductions
2. OT Assessment Methodology Overview
3. Analyzing Data and Comparing Results
4. Strategies to Implement Solutions
5. Final Thoughts and Q&A

INTRODUCTIONS

Mandie Grosskopf,
Manager at Security Risk Advisors

GIAC Response & Industrial Defense, Cybersecurity Analyst+, Security+, Network+, Security Analytics Professional

- EMEA headquarters in Kilkenny, Ireland
- Co-Lead of OT/ICS service line
- Designed, expanded, and remediated greenfield and brownfield OT cybersecurity programs and elements
- Owner of OT Tabletop Exercises, OT Cybersecurity Maturity Assessments, Cybersecurity Resiliency Act gap assessments and program remediation services
- Lover of animals, travel, and a good book

THE QUESTION TO ASK WHEN YOU LOOK AT SECURITY IS …WHETHER IT'S WORTH THE TRADE-OFF.

-BRUCE SCHNEIER

DIFFERENT PRIORITIES FOR DIFFERENT ENVIRONMENTS

Information Technology

Lifecycle
3-5 years

Updates & Patches
Frequent, usually monthly

CIA Triad
Confidentiality of data is often the priority

Modern, Secure Protocols
Less backwards compatibility needs

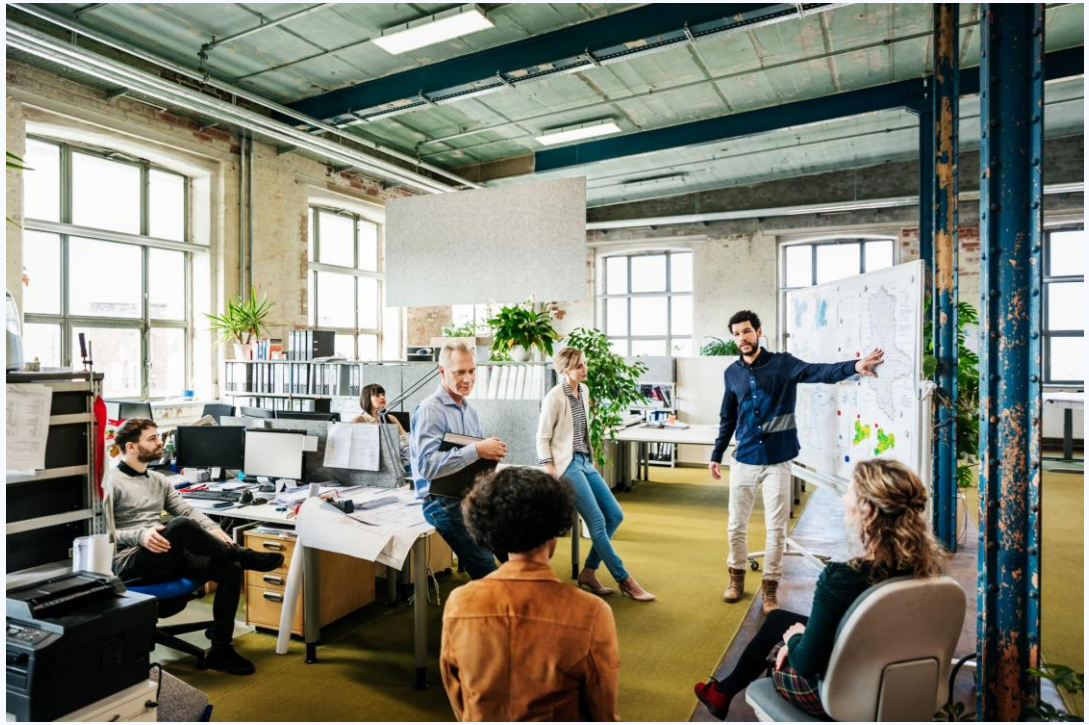
Operational Technology

Lifecycle
10-20 years+

Updates & Patches
Infrequent, maybe yearly

(S)AIC Triad
Safety, availability of machinery is priority

Insecure by Design Protocols
High need for backwards compatibility



OT Assessment Methodology Overview

ASSESSMENT METHODOLOGY

	OT Security Maturity Assessment	OT Penetration Test Assessment	OT Purple Team Assessment
01 - Scoping	•Define rules of engagement, assessment scope, and site resources		
02 - Info Gathering	•Review documentation •Interview staff	•Conduct OSINT •Target prioritization	•Assumed compromise approach
03 - Evaluation	•Analyze data against frameworks	•Manual on-site testing •Gentle exploit attempt	•Open book pen test •Collaborative exercise
04 - Remediation	•Prioritized maturity roadmap	•Observations matrix with recommendations	•ID top fixes, remediations mapped to MITRE ATT&CK
05 - Reporting	•Report and socialize findings, prioritized next steps, and proposed roadmap with stakeholders		

CONSISTENT AREAS WITH IMPROVEMENT OPPORTUNITIES

COMBINED GOVERNANCE

ASSET MANAGEMENT

COMPREHENSIVE INCIDENT RESPONSE

Analyzing Data and Comparing Results

COMPANY PROFILES

- Medical Diagnostics and Testing
- Chemical Manufacturing, Industrial & Specialty
- Leisure Travel, Hospitality; Maritime
- Automotive, Automotive Parts Manufacturing
- Pharmaceutical, Life Sciences
- Consumer Packaged Goods, Beverage Focus

Medical Diagnostics and Testing

Analysis and Recommendation Deep Dive

SELECT NOTABLE FINDINGS – ASSET MANAGEMENT

On Paper: Maturity Assessment Findings	Sites Impacted	On the Wire: Penetration Test Findings
Security policies are developed, documented, and designed to cover all applicable environments; they are reviewed periodically to confirm risk tolerance levels.	4	Vulnerable or end-of-life systems and firmware
	6	Sensitive data accessible
	1	Weak domain password policy
	3	Misconfigured AD CS templates

Key Takeaway: IT polices must, at minimum, be adapted to OT environments or they will be interpreted as not applicable.

SELECT NOTABLE FINDINGS – ACCESS MANAGEMENT

On Paper: Maturity Assessment Findings	Sites Impacted	On the Wire: Penetration Test Findings
Physical and digital access to assets is limited to designated authorized users, and the list of authorized personnel is updated and maintained. High-risk areas should have stricter physical access controls.	1	Unsecured access to critical infrastructure
	4	Ineffective or susceptible physical access controls
	3	Publicly available network jack
	1	Physical access bypass
	2	Excessive outbound network access on Master HMI PCs/Use of dual-homed topology
	1	PLC allows remote mode switching
	1	Elevator physical bypass

Key Takeaway: Asset access must be regularly inspected to verify standards are met and maintained.

SELECT NOTABLE FINDINGS – NETWORK SEPARATION

On Paper: Maturity Assessment Findings	Sites Impacted	On the Wire: Penetration Test Findings
All sites shall have a boundary between different environments (corporate, R&D, lab, OT) as well as between assets deemed critical.	3	Lack of segmentation between OT and corporate
	4	Insufficient site-to-site access controls
	1	Remote access gateway takeover
	2	Lack of isolation of production-critical assets

Key Takeaway: Segmentation must not be assumed, it must be verified with technical assessments.

COMPANY FINDINGS

Leisure Travel, Hospitality; Maritime

On Paper

Never share, show, or write down passwords other than to authorized users. Digital password records should be maintained in encrypted/password protected files. Default passwords must be changed. Passwords must meet minimum complexity requirements.

VS

On the Wire

- Weak domain administrator credentials.
- Weak or easily guessable passwords for sensitive systems.
- Insecure storage of credentials.
- Shared local administrator password.
- Default credentials.

Value Add:

- Designed and executed OT-specific tabletop exercises
- Rewrote IRP to include OT

COMPANY FINDINGS

Pharmaceutical, Life Sciences

On Paper

OT, Lab, and Research & Development networks are not allowed to have active IR actions taken, regardless of severity.

VS

On the Wire

- Overly permissive site-to-site and site-to-corporate network segmentation.
- Communication pathways for alert notifications were inconsistent and often overlooked.

Value Add:

- Created separate OT IRP invoked from IT IRP
- Created OT IR runbooks
- Created OT IR RACI matrix

COMPANY FINDINGS

Chemical Manufacturing, Industrial & Specialty

On Paper

No OT specific Standards, policies or procedures.

Company Stated Goal: Enabling passive monitoring to provide detection capabilities.

VS

On the Wire

- Over 15K OT alerts per day from network monitoring tools.
- IT defenders unfamiliar with OT assets and terms spending hours researching each alert.

Value Add:

- Tuned alerts until 1-2 per day
- Added AI agents for PCAP parsing and OT info to alerts

COMPANY FINDINGS

Automotive, Automotive Parts Manufacturing

On Paper

Company Stated Goal: Confirm OT visibility and detection capabilities.

VS

On the Wire

- Lateral movements and other persistence techniques were logged but not alerted on.
- OT network monitoring alerts were not sent to SOC team for monitoring and response.

COMPANY FINDINGS

Consumer Packaged Goods, Beverage Focus

On Paper

No outside networks allowed to be connected to manufacturing devices, subnets, or environment.

VS

On the Wire

- Devices on Guest network had direct access to PLCs.
- Misconfigured MDF switch; directly connecting Guest network to manufacturing network.

Strategies to Implement Solutions

IMPLEMENTING IMPROVEMENTS

Combined Governance

- ✓ Give OT a voice in governance of their systems and supporting IT
- ✓ Develop policies and procedures specific to OT

Try this: establish a "Center of Excellence" that brings IT, OT, and InfoSec teams together regularly to collaborate

Asset Management

- ✓ Include OT assets in risk register(s)
- ✓ Develop global BCP/DR strategies in conjunction with asset owners and OT SMEs

Try this: work directly with site management to understand local documentation on maintenance coverage

Comprehensive Incident Response

- ✓ Include OT SMEs in writing policies on specific actions IR can take
- ✓ Design IR communication and approval matrices for OT assets

Try this: conduct a Tabletop Exercise to work through IR scenarios with IT, OT, InfoSec, and other business teams

Final Thoughts, Q&A

FINAL THOUGHTS

Collaboration can help break silos

When teams understand each other's priorities and roadblocks, they can better work cooperatively and avoid rigid thinking

OT must have a voice in their own governance

OT may run on IT infrastructure, but its purpose is different so it must be governed different
OT needs to have a seat at the table so their priorities and limitations can be understood

Trust, but *test*

1. Pen tests can evaluate efficacy of technical controls in place
2. Purple teams can verify visibility and response playbooks
3. Tabletop exercises assess roles, responsibilities, and incident response plans
4. Restoration and/or recovery tests must be conducted annually for all mission-critical systems

Mandie Grosskopf
Manager at Security Risk Advisors

Questions?

Let’s connect and continue the conversation!